

Syrian Wallet App - Backend Development Plan

Stack: NestJS + PostgreSQL + Prisma + Redis + BullMQ

Timeline: 63 days to MVP launch

Post-MVP: Virtual Cards → Payment Gateway → MTOs/Banks

Week 1-2: Foundation & Security (Days 1-14)

Days 1-3: Project Setup

- Initialize NestJS with modules: auth, users, wallets, transactions, kyc, admin, devices, notifications, security
- Configure PostgreSQL + Prisma, Redis (caching, locks, sessions), BullMQ (async jobs)
- Docker Compose for local dev
- Structured logging with correlation IDs

Days 4-7: Authentication & Mobile Security

Core Auth

- Phone-based registration with SMS/EMAIL OTP
- JWT: 15-min access + 7-day refresh tokens
- Password reset flow
- Bcrypt hashing (cost: 12)
- Rate limiting: 5 attempts per 15min, 30-min lockout after failures
- Session tracking: device, IP, location

RBAC

- Roles: USER, ADMIN, SUPER_ADMIN, MERCHANT (future)
- Granular permissions system

Days 8-14: Mobile Security Layer

PIN & Biometric

- 6-digit transaction PIN (separate from password, bcrypt hashed)
- Biometric public key storage
- PIN lockout: 5 failures = 30-min lock
- Short-lived tokens (5-min) for sensitive operations

Device Management

- Device registration (UUID, OS, model, FCM token)
- Max 5 trusted devices per user
- New device verification via SMS OTP
- Device revocation capability

Request Security

- HMAC-SHA256 signature verification
- Timestamp validation (reject >5 min old)
- Nonce tracking in Redis (5-min TTL)

Encryption

- AES-256-GCM for sensitive responses (balance, transactions, PII)
- RSA-2048 key exchange
- Key rotation every 90 days

Week 1–2 Testing

- Auth flows end-to-end
- PIN/biometric/device management
- Security: JWT tampering, brute force, replay attacks
- Backup creation and restore verification

Models: User, Session, Device, AuditLog

Week 3: KYC System (Days 15-21)

Days 15-18: KYC Document Collection

KYC Tiers

- Tier 1: Phone verification only – {value} daily, basic transfers only
- Tier 2: National ID + selfie + proof of address - {value} daily, all features
- Tier 3: Enhanced + income proof - {value} daily, future virtual cards

Document Submission

- Types: national_id_front, national_id_back, selfie with id
- Upload to S3 (encrypted, pre-signed URLs with 5-min expiry)
- File validation: type, size (<10MB), quality
- Status: not_started → documents_uploaded → pending_review → verified/rejected/requires_resubmission

Days 19-21: KYC Review & Automation

Manual Review Process

- Compliance dashboard with pending queue
- View all documents, extracted data, user history
- Approve/reject with reason
- Request additional documents
- Bulk actions

Automated Wallet Creation

- Trigger on KYC verified
- Background job creates wallet with tier-appropriate limits
- Set wallet status to active
- Send welcome notification

Edge Cases

- KYC rejected → resubmit after 24 hours
- Document quality issues → request resubmission

Week 3 Testing

- KYC submission end-to-end
- Document upload and validation
- KYC approval → wallet creation
- All edge cases
- Load test: 100 submissions/hour

Models: KYCSubmission, KYCDocument, ComplianceReview

Week 4: Wallet System (Days 22-28)

Days 22-25: Wallet Creation & Management

Wallet Creation

- Auto-create on KYC approval
- Status: pending_kyc → active → frozen → closed
- Support multi-wallet (SYP + USD)
- Balance and available_balance tracking

Operations

- Get balance (encrypted, Redis cache 30s TTL)
- Force refresh, statement with filters
- Admin freeze/unfreeze with reason
- Manual adjustment (requires approval + audit)

Transaction Limits (Tier-Based)

- Tier 1: {value} daily, {value} monthly
- Tier 2: {value} daily, {value} monthly
- Tier 3: {value} daily, {value} monthly
- Velocity: max {value} transactions/hour
- Per-transaction min/max amounts

Days 26-28: Wallet Testing & Optimization

- Wallet creation on KYC approval
- Balance caching and refresh
- Freeze/unfreeze workflows
- Limit enforcement
- Multi-currency support

Week 4 Deliverables

- Fully functional wallet system
- Tier-based limit enforcement
- Admin controls
- Encrypted balance retrieval

Models: Wallet, TransactionLimit

Week 5: Transaction Engine Foundation (Days 29–35)

Days 29–32 — Double-Entry Ledger & Core Transaction Engine

Double-Entry Ledger System

- Every transaction produces 2+ **immutable ledger entries** (debit + credit).
 - Supported transaction types:
deposit, withdrawal, p2p_transfer, fee, reversal, adjustment.
 - Status lifecycle:
pending → processing → completed / failed / cancelled / reversed / expired.
 - Balance rule:
 $\text{SUM}(\text{credits}) - \text{SUM}(\text{debits}) = \text{wallet_balance}.$
 - Append-only ledger with versioning, trace ID, correlation ID.
-

Transaction Processing Components

- **Idempotency keys** (Redis, TTL 24h) to avoid duplicates.
 - **Distributed wallet locks** (Redlock or DB row-level locking).
 - **Atomic updates**:
ledger creation + balance updates must succeed or rollback together.
 - **Consistency guarantees** for concurrency and race conditions.
-

Validation Framework

- Both parties must be **KYC-verified**.
 - Wallets must be **active / not frozen**.
 - **Sufficient balance** including fees.
 - **Amount within min/max limits**.
 - **No self-transfers**.
 - **Velocity checks** (per day/week).
 - **Fraud & risk checks** (device, IP, anomalies).
-

Days 33–35 — Worker Queues, Status Automation & Notifications

BullMQ Queues

- **transaction-processing** (concurrency: 10)
- **fraud-check** (concurrency: 5)
- **notifications** (concurrency: 50)
- Retry policy: **3 attempts**, exponential backoff (1s → 5s → 15s).
- **Dead Letter Queue (DLQ)** for failed tasks.
- Job visibility timeout to avoid stuck processing.

Engine Features

- Real-time transaction execution.
 - Automatic status transitions:
pending → **processing** → **completed/failed**.
 - Fraud worker integration.
 - Notification dispatch (SMS/Push/Email).
 - Full audit logs for every state change.
-

Week 5 Testing

- High-concurrency transaction simulation.
 - Ledger integrity: **credits** = **debits** for every transaction.
 - Idempotency under duplicate request load.
 - Lock contention testing on same wallet.
 - Fraud rule validation tests.
 - Load testing: **50 TPS**, with p95 < **200 ms**.
-

Week 6: QR P2P Transfers & Transaction History (Days 36–42)

All money movement in Week 6 relies on the Transaction Engine from Week 5. Week 6 only adds the QR workflow and history/receipt layer *on top* of the existing engine.

Days 36–38 — QR-Based P2P Transfer Layer (Built on Week 5 Engine)

QR Code Structure

- **Static user QR code** (persistent).
- Contains a **signed & encrypted payload** so it cannot be forged.
- QR contains only safe identifiers (never raw user IDs).

QR Transfer Workflow (Uses Week 5 Transaction Engine)

1. Recipient displays their static QR code.
2. Sender scans the QR.
3. System validates QR signature + recipient's wallet status.
4. Sender enters the amount.
5. Preview screen displays:
 - amount
 - fee
 - sender's balance after transfer
6. Sender enters PIN (via auth service).
7. Engine validates: limits, balance, KYC, velocity, fraud rules.
8. **Call Transaction Engine (Week 5):**
 - Lock both wallets
 - Create ledger entries
 - Update balances atomically
 - Apply fees
 - Generate transaction record
9. Engine updates status (processing → completed).
10. Notifications sent to both users.
11. Return final transfer receipt.

Features Delivered

- Static QR code generation.
 - QR validation service.
 - QR → P2P Transfer API (calls transaction engine).
-

Days 39–42 — Transaction History & Digital Receipts

Transaction History

- Paginated, filterable history:
 - date range
 - transaction type
 - status
 - amount range
- Optimized queries using:
 - wallet_id + created_at
 - type/status indexes

Digital Receipts

Formats:

1. **PDF Receipt** (signed, tamper-resistant)
2. **QR Receipt** containing a verifiable signature

Features:

- Generate receipt by transaction ID.
- Validate receipt authenticity.
- Include trace ID and ledger references.

Export Options

- CSV
 - Excel (multi-sheet)
 - PDF Summary Report
-

Week 6 Testing

- Static QR generation/validation.
- Complete QR → Engine → Ledger execution flow.
- Wallet lock/unlock correctness.
- Limit and fraud rule validation.
- History pagination + filter logic.
- Receipt generation in all formats.
- Export function testing (CSV, Excel, PDF).

Week 7: Fraud Detection & 2FA (Days 43-49)

Days 43-46: Fraud Detection System

Velocity Checks

- 10 transactions in 10 min → flag + 2FA
- 50/day → flag + manual review
- 100/week → escalate
- 5x average amount → flag

Anomaly Detection

- First transaction >500k → 2FA + delay
- New recipient large amount → flag
- Unusual hours (2-6 AM) → flag
- Geolocation anomaly → flag
- Rapid transfers to multiple recipients → flag
- Structuring (just below limits) → flag

Risk Scoring (0-100)

- Velocity: 0-30 pts
- Amount: 0-25 pts
- Recipient: 0-20 pts
- Time: 0-10 pts
- Location: 0-10 pts
- History: 0-5 pts

Actions

- 0-30: Process normally
- 31-50: Flag, process
- 51-70: 2FA + 5-min delay + flag
- 71-100: Block + freeze + escalate

Days 47-49: Two-Factor Authentication

Triggers

- Large transaction (>500k)
- High risk score (>50)
- First transaction to new recipient
- After account recovery

Implementation

- 6-digit OTP via SMS + email
- 5-min expiry, max 3 attempts
- Failed 3 times: cancel + 15-min lock

2FA For

- Large transfers
- PIN/password change
- Add new device
- Wallet recovery

Week 7 Testing

- Fraud detection scenarios
- Risk scoring accuracy
- 2FA flows
- Alert generation
- False positive rate
- Load test: 1000 transactions/min

Models: FraudAlert, TransactionRiskScore

Week 8: Admin Panel (Days 50-56)

Days 50-53: Admin Dashboard & User Management

Security

- Mandatory TOTP 2FA
- 15-min session timeout
- IP whitelist optional
- All actions logged

User Management

- List with filters: name, phone, KYC status, wallet status
- User details: profile, KYC, wallet, transactions, devices, alerts
- Suspend/activate with reason
- Custom limits override
- Admin notes

KYC Management

- Review queue sorted by submission date
- View documents, history
- Approve with tier assignment
- Reject with reason
- Request additional documents

Transaction Management

- All transactions with filters
- Real-time updates (WebSocket)
- Transaction details with timeline
- Flag suspicious
- Reverse (SUPER_ADMIN only, 2-person rule)

Days 54-56: Audit Logs & Backup Management

Audit Logs

- Filter by entity, action, actor, date
- Immutable, 7-year retention
- Export to CSV
- Real-time monitoring

Backup Management

- Health status dashboard
- List all backups with timestamps/sizes
- Manual backup trigger
- Test restore to staging
- Backup metrics: duration, storage, success rate

Week 8 Testing

- Admin auth with 2FA
- All CRUD operations
- Permission-based access
- User suspension
- Transaction reversal
- Audit log integrity
- Backup trigger/restore

Models: AdminUser, AuditLog

Week 9: Security Hardening & Launch Prep (Days 57-63)

Days 57-58: Security Hardening

Application

- Helmet.js: CSP, X-Frame-Options, HSTS
- CORS: whitelist mobile domains only
- Rate limiting :
- Input validation: Joi/Zod strict schemas
- SQL injection prevention: Prisma only
- XSS prevention: sanitize + CSP
- File upload: whitelist types, 10MB limit, malware scan, S3 storage

Infrastructure

- Database: SSL/TLS, AES-256 at rest, VPC only
- Redis: password auth, encrypted connections
- SSL/TLS: TLS 1.3, certificate pinning for mobile
- Secrets: AWS Secrets Manager, 90-day rotation

Testing

- npm audit, OWASP ZAP scan
- Manual penetration testing
- Test: JWT tampering, auth bypass, SQL injection, XSS, CSRF, rate limits

Days 59-63: Comprehensive Testing & Launch Prep

Integration Tests

- Complete journeys:
 - User: Register → Verify → PIN → KYC → Wallet → P2P Transfer
 - Transaction: Deposit → P2P → Withdrawal → Receipt
 - Admin: Login → Review KYC → Monitor → Flag → Resolve

Load Testing

- Normal: 50 TPS, 100 users, 1 hour (p95 <200ms, p99 <500ms, error <0.1%)
- Peak: 200 TPS, 500 users, 15 min (p95 <500ms, p99 <1s, error <0.5%)
- Stress: increase until break, identify bottlenecks
- Spike: 50→500 TPS sudden

Disaster Recovery

- Database failure simulation
- Point-in-time recovery
- Full system failure
- Backup encryption/decryption
- Measure RTO (<4 hours)

Documentation

- API: Swagger with all endpoints, examples, error codes
- Developer: README, setup, architecture, testing
- Operations: deployment, runbook, monitoring, disaster recovery
- Backup procedures: schedule, manual trigger, restore steps, verification
- Mobile integration: auth, signing, encryption, FCM, error handling

Pre-Production Checklist

- All tests passing (80% coverage, 95% critical)
 - No security vulnerabilities
 - Migrations tested, indexes optimized
 - Secrets in AWS Secrets Manager
 - SSL/TLS configured
 - Monitoring configured (Sentry, logs, APM, alerts)
 - Production environment ready
 - CI/CD pipeline tested
 - Backup system verified
 - Disaster recovery plan reviewed
 - Team trained
-

Post-MVP Roadmap

MTO & Bank Integration

- MTO partners (Al-Foaad, Al-Harm....)
- International remittances
- Bank account linking
- Direct bank transfers
- Exchange rate management

Virtual Cards

- Card processor partnership
- Instant issuance, tokenization (PCI-DSS)
- Authorization/settlement
- 3D Secure, card controls

Payment Gateway

- Merchant onboarding (KYB)
- API key management
- Checkout, payment links, QR codes
- Merchant webhooks/dashboard
- Refunds, disputes

Security Summary

Authentication: JWT (15min + 7day) + PIN + biometric + 2FA + device management (max 5) + RBAC

Encryption: AES-256-GCM (data) + RSA-2048 (keys) + HMAC-SHA256 (signing) + TLS 1.3 + encrypted backups

Protection: Rate limiting + input validation + SQL/XSS/CSRF prevention + timestamp validation + idempotency

Monitoring: Audit logs (7-year, immutable) + fraud detection + real-time alerts + backup monitoring

Disaster Recovery: Daily encrypted backups (30-day retention) + point-in-time recovery + RPO <1hr + RTO <4hr + monthly drills